

CATATAN BELAJAR

Pengenalan & Pengawasan

Risiko Siber

Industri Sistem Pembayaran

Departemen Surveilans Sistem Pembayaran & Pelindungan Konsumen

Untuk Peserta PCPM | Mudah Dipahami | Dilengkapi Latihan Soal

Berdasarkan Materi PCPM 40 | Bank Indonesia, 23 April 2026

DAFTAR ISI	
BAB 1	Dasar Hukum Pengawasan Risiko Siber
BAB 2	Siklus Pengawasan Sistem Pembayaran
BAB 3	Asesmen Keandalan Infrastruktur TI (TIKI)
BAB 4	Framework KKS — PBI No. 2 Tahun 2024
BAB 5	Issue & Risiko Siber Terkini
BAB 6	Evolusi Kejahatan Siber pada Industri SP (2019–2026)
BAB 7	Penanganan Kasus Siber (4 Case Study)
BAB 8	Hasil Asesmen & Kesimpulan
BAB 9	LATIHAN SOAL MULTIPLE CHOICE (40 Soal)
BONUS	Kamus Istilah & Cheat Sheet

BAB 1 — DASAR HUKUM PENGAWASAN RISIKO SIBER

Pengawasan risiko siber pada industri Sistem Pembayaran oleh Bank Indonesia didasarkan pada hierarki regulasi: **Undang-Undang** → **PBI** → **PADG** → **SEBI**. Seluruh ketentuan internal PJP (Penyedia Jasa Pembayaran) wajib mengacu pada ketentuan BI.

A. Undang-Undang (UU)

Regulasi	Tentang
UU No. 23 Tahun 1999 (terakhir diubah UU No. 4/2023)	Bank Indonesia — landasan kewenangan BI dalam pengawasan SP
UU No. 3 Tahun 2011	Transfer Dana
UU No. 27 Tahun 2022	Pelindungan Data Pribadi (PDP)
UU No. 4 Tahun 2023	Pengembangan dan Penguatan Sektor Keuangan (P2SK)

B. Peraturan Bank Indonesia (PBI) — Regulasi Kunci

PBI	Tentang	Keterangan
PBI No. 22/23/PBI/2020	Sistem Pembayaran	Kerangka umum pengaturan SP
PBI No. 23/6/PBI/2021	Penyedia Jasa Pembayaran (PJP)	Perizinan dan kewajiban PJP
PBI No. 2 Tahun 2024 ★	Keamanan Sistem Informasi & Ketahanan Siber (KKS)	REGULASI UTAMA siber — berlaku untuk PSP, pelaku pasar uang & valas
PBI No. 3 Tahun 2023	Pelindungan Konsumen Bank Indonesia	Perlindungan konsumen layanan SP
PBI No. 5 Tahun 2024	Standardisasi Kompetensi di Bidang SP (SK-SP)	Standar kompetensi SDM di industri SP
PBI No. 10 Tahun 2025	Pengaturan Industri Sistem Pembayaran	Regulasi terbaru industri SP (2025)
PBI No. 19/8/PBI/2017	Gerbang Pembayaran Nasional (GPN)	National Payment Gateway — infrastruktur domestik

C. PADG dan Surat Edaran Bank Indonesia (SEBI)

Regulasi	Tentang
PADG No. 24/7/PADG/2022	Penyedia Jasa Pembayaran dan Penyelenggara Infrastruktur SP
PADG No. 23/25/PADG/2021	Penyelenggaraan Bank Indonesia-Fast Payment (BI-Fast)
PADG No. 32 Tahun 2025	Pengaturan Sistem Pembayaran (terbaru 2025)
PADG No. 20 Tahun 2023	Tata Cara Pelaksanaan Pelindungan Konsumen Bank Indonesia
SEBI No. 17/52/DKSP (2015)	Implementasi Standar Nasional Teknologi Chip & PIN Online 6 Digit untuk Kartu ATM/Debet

BAB 2 — SIKLUS PENGAWASAN SISTEM PEMBAYARAN

Pengawasan SP oleh Bank Indonesia bersifat **siklus berkelanjutan** yang terdiri dari tiga tahap utama: **Surveilans → Pemeriksaan → Evaluasi dan Tindak Lanjut**. Fondasi pengawasan bertumpu pada 4 pilar: **People, Policy, Process, Technology**.

3 Tahap Siklus Pengawasan

Taha p	Nama	Isi/Kegiatan	Output
1	SURVEILANS	Pemantauan (laporan + informasi lain), identifikasi risiko, penilaian risiko	Identifikasi & asesmen risiko penyelenggara
2	PEMERIKSAAN	Pemeriksaan langsung (on-site) ke penyelenggara — Full Scope atau Thematic	Konfirmasi hasil surveilans, temuan tambahan
3	EVALUASI & TINDAK LANJUT	Evaluasi berkala, penerapan sanksi bila ada pelanggaran	Sanksi, Rekomendasi, Monitoring komitmen, Koordinasi otoritas lain

Tools/Laporan yang Disampaikan PJP/PIP kepada BI

Tools / Laporan	Frekuensi	Keterangan
Laporan Data Pokok TI	Tahunan	Data infrastruktur TI penyelenggara secara menyeluruh
Kuesioner Kecukupan Pengendalian TI	Tahunan	Penilaian mandiri kecukupan kontrol TI
Laporan Hasil Audit TI	Tahunan	Hasil audit TI oleh pihak independen
Laporan Hasil Penetration Testing Sistem SP	Tahunan	Hasil uji penetrasi keamanan sistem
Laporan Rekapitulasi Gangguan Sistem	Bulanan	Rekap seluruh gangguan sistem yang terjadi
Laporan Availability Infrastruktur TI	Bulanan	Tingkat ketersediaan sistem/infrastruktur TI
Laporan Insiden	Sewaktu-waktu	Laporan insiden siber/gangguan yang terjadi segera
Laporan KKS dan IIV	Semesteran / Tahunan	Laporan Ketahanan & Keamanan Siber serta Identifikasi Instrumen Vital
Cyber Threat Intelligence	Harian	Intelijen ancaman siber terkini — dipantau setiap hari

Suptech: Saat ini BI sedang mengembangkan **Supervisory Technology (Suptech)** baik dari sisi data collection maupun data analytics untuk meningkatkan efektivitas surveilans.

BAB 3 — ASESMEN KEANDALAN INFRASTRUKTUR TI (TIKI)

Keandalan infrastruktur TI Sistem Pembayaran dinilai menggunakan framework **TIKI**: **T**ransaksi, **I**nterkoneksi, **K**ompetensi, **M**anajemen Risiko, **I**nfrastruktur Teknologi. Penilaian mencakup 3 dimensi utama yang menghasilkan skor keandalan.

Kriteria Penilaian TIKI

- T — Transaksi**: Volume dan nilai transaksi yang diproses penyelenggara
- I — Interkoneksi**: Keterkaitan/keterhubungan dengan sistem pembayaran lain
- K — Kompetensi**: Kemampuan SDM dan organisasi dalam mengelola SP
- M — Manajemen Risiko**: Pengelolaan risiko operasional TI dan siber
- I — Infrastruktur Teknologi**: Kecukupan dan keandalan infrastruktur TI yang digunakan

3 Dimensi Penilaian Keandalan (Faktor I)

Dimensi	Komponen	Cakupan Penilaian	Referensi
1 Infrastruktur Standar Minimum SP	Risiko Inheren TI (Infrastruktur Teknologi)	1. Kesesuaian Fungsional 2. Efisiensi Kinerja 3. Kompatibilitas 4. Kemampuan Interaksi 5. Keandalan	ISO 25010:2023 (SQuaRE)
2 Governance SP	TKMR TI (Tingkat Kematangan Manajemen Risiko)	1. Konteks Organisasi 2. Strategi Manajemen Risiko 3. Kebijakan/Prosedur 4. Peran & Tanggung Jawab 5. Kontrol, Sistem, Akses, Konfigurasi 6. Pengendalian Risiko Kerja Sama Penunjang	NIST 2.0 (2024) BIS Operational Risk (2020)
3 Keamanan Siber SP	Maturitas Siber	1. Strategi & Kebijakan 2. Audit & Budaya 3. Identifikasi 4. Proteksi 5. Deteksi 6. Respon 7. Pemulihan	PBI No. 2 Tahun 2024 (PBI KKS)

Skala Hasil Penilaian Keandalan Infrastruktur TI

Skor	Kategori	Makna
1	Unreliable (Tidak Andal)	Infrastruktur TI tidak andal, risiko sangat tinggi
2	Usually Reliable (Kurang Andal)	Andal dalam kondisi tertentu, masih perlu perbaikan signifikan
3	Fairly Reliable (Cukup Andal)	Cukup andal, perlu peningkatan di beberapa area
4	Reliable (Andal)	Andal, pengendalian memadai
5	Completely Reliable (Sangat Andal)	Sangat andal, pengendalian sangat kuat

BAB 4 — FRAMEWORK KKS: PBI NO. 2 TAHUN 2024

PBI No. 2 Tahun 2024 tentang Keamanan Sistem Informasi dan Ketahanan Siber (KKS) adalah regulasi utama pengawasan siber. Kerangka pengaturan meliputi 3 Pilar: (1) Tata Kelola, (2) Pencegahan, (3) Penanganan, didukung landasan Pengawasan dan Kolaborasi.

Tujuan dan Sasaran KKS

- **Tujuan:** Menciptakan KKS pada Penyelenggara untuk mendukung tujuan Bank Indonesia dalam mencapai stabilitas nilai rupiah, stabilitas sistem pembayaran, dan mendukung pertumbuhan ekonomi berkelanjutan.
- **Sasaran 1:** Meningkatkan KKS Penyelenggara sehingga dapat mencegah dan menangani dampak serangan siber.
- **Sasaran 2:** Meningkatkan manajemen risiko siber Penyelenggara.
- **Sasaran 3:** Memperkuat pengawasan dan kolaborasi dalam pencegahan dan penanganan insiden siber.

3 Pilar Framework KKS

TATA KELOLA	PENCEGAHAN	PENANGANAN
Strategi & Kebijakan: 1. Rencana Strategis KKS 2. Kebijakan, Standar, & Prosedur KKS 3. Fungsi Organisasi KKS 4. Manajemen KKS 5. Manajemen Risiko Siber Audit & Budaya: 1. Audit KKS 2. Budaya KKS	Identification (Identifikasi): 1. Identifikasi Risiko Siber 2. Asesmen Risiko Siber 3. Analisis Dampak Bisnis Protection (Proteksi): 1. Membangun Sistem Pertahanan 2. Pengamanan & Pelindungan Data Detection (Deteksi): 1. Pemantauan 2. Analisis Hasil Pemantauan 3. Analisis Percobaan Serangan 4. Analisis Malicious/Unauthorized Code 5. Pemeliharaan & Pengujian Sistem Deteksi	Response (Respons): 1. Rencana Penanganan & Pemulihan 2. Simulasi & Uji Coba 3. Pelaksanaan Penanganan Insiden 4. Komunikasi Tindakan Penanganan Recovery (Pemulihan): 1. Pelaksanaan Pemulihan Insiden 2. Perbaikan Berkelanjutan 3. Komunikasi Pemulihan Insiden

Prinsip & Elemen KKS

Prinsip KKS: Accountability | Comprehensive Strategy | Embedded Cyber Risk Management | Cybersecurity Culture | Readiness for Incident

Elemen KKS: People | Process | Technology

Pengawasan & Kolaborasi: (1) Pertukaran Informasi; (2) Pencegahan contagion effect; (3) Self-Regulatory Organization

BAB 5 — ISSUE & RISIKO SIBER TERKINI

Pada masa pandemi, **92% IT Audit & Security Professionals** menyatakan bahwa cybercrime semakin meningkat, menjadikan data dan informasi sangat kritikal. Biaya kejahatan siber Indonesia meningkat dari **\$3,43 M (2018)** menjadi **\$6,48 M (2028)**.

Most Common Threat Actors (Pelaku Ancaman Terbanyak)

Peringkat	Jenis Pelaku	Persentase	Keterangan
1	Cybercriminals	22%	Pelaku kriminal bermotif finansial
2	Hackers	19%	Peretas independen/kelompok
3	Malicious Insiders	11%	Orang dalam yang berniat jahat
4	Non-malicious Insiders	10%	Kelalaian/ketidaksengajaan orang dalam
5	Nation State Attackers	9%	Serangan yang disponsori negara
6	Hacktivist	8%	Aktivis hacker — bermotif ideologi/politik

Top 3 Attack Vector (Vektor Serangan Teratas — BSSN 2024)

Vektor Serangan	Kode MITRE	Penjelasan
Active Scanning	T1595	Pihak yang mengancam melakukan pemindaian untuk mengumpulkan informasi yang dapat dieksploitasi dari sistem target
Compromised Account	T1586	Pihak yang mengancam menggunakan akun yang sudah diretas oleh perangkat lunak pencuri (malware) untuk mengakses sistem
Exploit Public-Facing Application	T1190	Pihak yang mengancam menggunakan kerentanan di situs web untuk melakukan serangan: Injeksi SQL, Unggah Berkas, XSS, dan sejenisnya

Jenis-Jenis Malware

Jenis Malware	Definisi
Adware	Software untuk menampilkan iklan di komputer dan mengumpulkan informasi pribadi pengguna
Ransomware ★	Malware yang membatasi penggunaan komputer sampai pemilik membayar tebusan kepada pembuat malware. Top 5 di Indonesia: Lunamoth, WannaCry, Locky, LockBit, GandCrab. Pada 2023 mencapai all-time high: 10% organisasi global terdampak.
Trojan	Malware yang menyamar sebagai software yang sah/legal
Virus	Malware yang menempelkan dirinya pada program yang sering digunakan — dieksekusi saat program berjalan
Worm	Malware yang dapat mereplikasi diri sendiri untuk menyebar ke komputer lain

BAB 6 — EVOLUSI KEJAHATAN SIBER PADA INDUSTRI SP (2019–2026)

Kejahatan siber pada industri Sistem Pembayaran terus berevolusi mengikuti perkembangan teknologi dan konteks geopolitik. Penting untuk memahami pola evolusinya agar dapat mengantisipasi ancaman berikutnya.

2019–2021

"Find and Exploit"

- Gelombang besar digitalisasi SP — banyak pelaku industri mengembangkan mobile apps.
- Kurang memadainya proses SDLC (Software Development Lifecycle) membuka celah sistem yang dimanfaatkan fraudster.
- Kasus: Bug mobile banking yang dapat mentransfer dana tanpa mendebit saldo, bug saldo bertambah/berkurang tanpa transaksi, skimming (bug ATM & belum memenuhi SNTC).

2021–2023

"Extort and Gain Fame"

- Serangan siber makin "affordable" — muncul Ransomware-as-a-Service (RaaS) di forum darkweb.
- Pelaku kriminal siber mencari publisitas & unjuk kemampuan dengan menyerang institusi besar.
- Kasus: Ransomware Bank, kebocoran data institusi negara, DDoS.
- Setelah serangan, grup kriminal mengklaim dan meminta uang tebusan (ransom).

2024–2025

Cyber Heist

- Dinamika geopolitik global mendorong tekanan ekonomi → fokus bergeser ke pencurian dana (cyber heist).
- Sasaran utama: institusi keuangan (PSP Bank & Nonbank) khususnya yang KKS-nya masih lemah.
- Kasus: Eksploitasi middleware untuk transfer dana ilegal tanpa deduct core banking.
- Akses ilegal ke core banking untuk ubah data nasabah dormant → account takeover.
- Fenomena "resurfaced breach": data lama dipublikasi ulang di forum black hat untuk mencari popularitas.

2025–2026

Third Party Risk

- Setelah PSP memperkuat KKS internal, pelaku ancaman mencari celah di mitra PSP.
- Loophole: managed service, vendor development, partner API — tidak semua mitra sudah terapkan KKS sekuat PSP.
- Kasus 1: Eksploitasi middleware SP yang dikelola vendor managed service.
- Kasus 2: Pengiriman perintah pencairan/pengiriman dana masif dari mitra API yang sistemnya diretas.
- Kasus 3: Kebocoran data PSP dari mitra/vendor → digunakan untuk ekstorsi kepada PSP.

BAB 7 — PENANGANAN KASUS SIBER (4 CASE STUDY)

Setiap kasus siber memiliki pola penanganan yang serupa: **Analisa Log → Money Trail → Identifikasi Infrastruktur → Pengamanan → Audit Forensik → Investigasi Internal → Recovery/Rebuild**. Yang berbeda adalah langkah pencegahan spesifik per jenis serangan.

Langkah Penanganan Umum (Berlaku untuk Semua Kasus Siber)

- 1. Melakukan analisa atas log transaksi yang dianggap anomali.
- 2. Melakukan money trail dan koordinasi dengan IASC.
- 3. Melakukan identifikasi atas seluruh infrastruktur yang terdampak.
- 4. Melakukan pengamanan atas infrastruktur yang terdampak untuk keperluan audit forensik.
- 5. Melakukan audit forensik jika diperlukan (tergantung jenis kasus).
- 6. Melakukan investigasi internal (apakah ada keterlibatan pihak internal atau vendor).
- 7. Melakukan proses recovery dengan me-rebuild seluruh infrastruktur terdampak, disertai penguatan keamanan.

KASUS 1: Insiden Transaksi Fraud APMK Melalui Kanal EDC/Mini ATM

Attacker mengeksploitasi celah pada mesin EDC/Mini ATM untuk melakukan transaksi fraud APMK (Alat Pembayaran Menggunakan Kartu). Melibatkan jaringan Merchant Aggregator, Server Host, HSM, dan Lembaga Switching. Pada kasus ini **memerlukan audit forensik**.

Langkah Pencegahan Khusus:

- Memiliki fungsi organisasi, mekanisme, dan tools pemantauan transaksi anomali.
- Validasi kewajaran data EMV transaksi, termasuk kewajaran value Authentication Response Crypto (ARPC).
- Memastikan seluruh server layanan SP sudah up-to-date (tidak ada yang obsolete).
- Memastikan seluruh server telah terlindungi antivirus/EDR.
- Instal tools pengamanan jaringan server PSP dengan prinsip least privilege access.

Sebagai Bank Acquirer:

- Memastikan proses know your merchant yang memadai — verifikasi kewajaran kegiatan dan lokasi usaha.
- Menerapkan mekanisme pemantauan kesesuaian profil merchant dengan transaksi.
- Memiliki tools pemantauan transaksi anomali via kanal EDC/Mini-ATM secara 24/7.
- MELARANG penggunaan EDC berbasis Android.
- Memastikan fitur EDC di merchant HANYA untuk purchase (tanpa transfer dana).

KASUS 2: Risiko Anomali Transaksi Wholesale Payment

Pencurian dana pada PSP melalui eksploitasi sistem Wholesale Payment. Hard Token yang digunakan untuk otentikasi setiap transaksi dimanfaatkan untuk mengirim message "success transaction" palsu. **Memerlukan audit forensik. Ada keterlibatan pihak internal bank.**

Langkah Pencegahan Khusus:

- Pengelolaan Hard Token:** Simpan dan kelola hard token dengan ketat, catat, beri label, monitoring user ID yang menggunakan. Pastikan hard token tidak expired.

- **Kapasitas SDM IT:** Pastikan SDM IT memiliki pemahaman mendalam terhadap sistem wholesale payment. Adanya KPT dari HR terkait sanksi atas kelalaian yang menimbulkan cyber fraud.
- **Access Control:** Tutup akses privilege ke wholesale payment bagi yang tidak berkepentingan. Batasi akses fisik ke area operasional RTGS. Tutup RDP, VNC, SSH di firewall — akses hanya via PAM.
- **Security Tools:** Pastikan EDR/Antivirus berfungsi mendeteksi aktivitas malware dan powershell. Pantau query malicious di database (delete record/table). Monitor aktivitas level transaksi, akun, dan jaringan via FDS secara 24/7.

KASUS 3: Risiko Cyber Heist Melalui Middleware

Attacker mengakses Server C&C melalui internet lalu meretas endpoint/workstation. Dari sana masuk ke Middleware PJP melalui RDP/SSH. Middleware mengontrol Switching GPN, BI-FAST, dan Core Banking System. **Memerlukan audit forensik.**

Langkah Pencegahan Khusus:

- **Access Control:** Install firewall antar segment & server untuk inspeksi traffic dan logging. Larang akses internet pada infrastruktur TI SP Kritis. Tutup akses RDP, SSH, VNC, HTTP, FTP — alihkan ke PAM. Terapkan MFA untuk VPN dan PAM.
- **Security Tools:** Instalasi Antivirus/EDR-XDR pada seluruh server layanan SP dan surroundingnya. Integrasikan log dari security tools (AV, EDR/XDR, PAM, firewall) ke tools SIEM.
- **Good Governance IT:** Memiliki SDM, tools, dan mekanisme FDS 24/7. Lakukan pengkinian infrastruktur TI yang memasuki masa obsolete. Audit TI dan KKS serta pentest secara menyeluruh, berkala, dan independen.

KASUS 4: Risiko Cyber Fraud Melalui Celah di Mitra API Pembayaran

Attacker berhasil compromise sistem mitra → masuk ke Server Host API → menembus firewall jaringan PJP → mengeksploitasi Middleware BI-FAST/RTOL dan RTOL Host API. Dana ditransfer ke bank lain. Tren Third Party Risk paling relevan 2025-2026.

Langkah Pencegahan Khusus:

- Memastikan kepatuhan PJP selaku penyedia maupun Mitra API terhadap seluruh Standar Teknis dan Keamanan SNAP: rule firewall whitelist IP, implementasi WAF di server API, implementasi FDS.
- Melakukan audit berkala atas kesesuaian penerapan SNAP — baik di sisi PJP penyedia maupun mitra pengguna.
- Memiliki SDM, tools, dan mekanisme pemantauan aktivitas SNAP di level transaksi, akun, maupun jaringan melalui FDS secara 24/7.
- Bila teridentifikasi anomali dari sisi mitra: minta mitra lakukan asesmen log, audit forensik API gateway, rebuild infrastruktur terdampak.

BAB 8 — HASIL ASESMEN & KESIMPULAN

Hasil Penilaian Faktor M dan Faktor I PSP Utama (35 Bank Besar)

Kategori (I)	Rerata Skor	Tidak Andal	Kurang Andal	Cukup Andal	Andal	Sangat Andal
35 Bank Besar	3,85	0	1	18	16	0

Interpretasi: Rerata skor 3,85 artinya mayoritas 35 Bank Besar berada di kategori "Cukup Andal" (18 bank) hingga "Andal" (16 bank). Tidak ada yang mencapai "Sangat Andal" dan masih ada 1 bank yang "Kurang Andal". Artinya masih diperlukan upaya signifikan untuk mencapai tingkat ketahanan siber yang optimal.

Kesimpulan dan Tindak Lanjut BI

- Secara umum masih banyak PSP yang memiliki skor di bawah threshold.
- Diperlukan penyusunan **peta jalan/rencana strategis KKS** oleh masing-masing PSP.
- Diperlukan **sharing session secara reguler** kepada industri untuk meningkatkan pemahaman risiko siber dan tren insiden siber yang sering terjadi.
- Membuka dan mengelola **kanal komunikasi FAQ spesifik** terkait ketentuan KKS.
- Penguatan **koordinasi antar otoritas** dan industri.

BAB 9 — LATIHAN SOAL MULTIPLE CHOICE (40 SOAL)

Semua soal berdasarkan materi PPT Risiko Siber Sistem Pembayaran — Bank Indonesia, 23 April 2026.

— SOAL 1-10: DASAR HUKUM, SIKLUS PENGAWASAN & ASESMEN —

Soal 1: Departemen BI yang bertanggung jawab atas pengawasan risiko siber pada industri Sistem Pembayaran adalah...

- A. Departemen Pengelolaan Uang (DPU)
- B. Departemen Surveilans Sistem Pembayaran dan Pelindungan Konsumen (DSPPK)
- C. Departemen Kebijakan Sistem Pembayaran (DKSP)
- D. Departemen Manajemen Risiko Bank Indonesia

✓ **Jawaban: B. Departemen Surveilans Sistem Pembayaran dan Pelindungan Konsumen (DSPPK)**

■ *Penjelasan: Materi ini disampaikan oleh Departemen Surveilans Sistem Pembayaran dan Pelindungan Konsumen (DSPPK) Bank Indonesia pada 23 April 2026.*

Soal 2: PBI yang paling spesifik mengatur Keamanan Sistem Informasi dan Ketahanan Siber bagi PSP adalah...

- A. PBI No. 22/23/PBI/2020
- B. PBI No. 23/6/PBI/2021
- C. PBI No. 2 Tahun 2024
- D. PBI No. 10 Tahun 2025

✓ **Jawaban: C. PBI No. 2 Tahun 2024**

■ *Penjelasan: PBI No. 2 Tahun 2024 tentang Keamanan Sistem Informasi dan Ketahanan Siber (KKS) adalah regulasi utama yang mengatur keamanan siber bagi Penyelenggara Sistem Pembayaran, Pelaku Pasar Uang dan Valas.*

Soal 3: Undang-undang yang mengatur tentang Pelindungan Data Pribadi di Indonesia adalah...

- A. UU No. 3 Tahun 2011
- B. UU No. 27 Tahun 2022
- C. UU No. 4 Tahun 2023
- D. UU No. 23 Tahun 1999

✓ **Jawaban: B. UU No. 27 Tahun 2022**

■ *Penjelasan: UU No. 27 Tahun 2022 tentang Pelindungan Data Pribadi (PDP) adalah landasan hukum perlindungan data di Indonesia.*

Soal 4: Siklus Pengawasan Sistem Pembayaran terdiri dari tiga tahap berurutan, yaitu...

- A. Pemeriksaan → Surveilans → Evaluasi
- B. Surveilans → Evaluasi → Pemeriksaan
- C. Surveilans → Pemeriksaan → Evaluasi dan Tindak Lanjut
- D. Identifikasi → Asesmen → Monitoring

✓ **Jawaban: C. Surveilans → Pemeriksaan → Evaluasi dan Tindak Lanjut**

■ *Penjelasan: Siklus: (1) Surveilans (pemantauan, identifikasi, asesmen risiko) → (2) Pemeriksaan (on-site) → (3) Evaluasi dan Tindak Lanjut (sanksi, rekomendasi, koordinasi).*

Soal 5: Cyber Threat Intelligence dalam tools pengawasan BI disampaikan dengan frekuensi...

- A. Tahunan
- B. Semesteran
- C. Bulanan
- D. Harian

✓ **Jawaban: D. Harian**

■ *Penjelasan: Cyber Threat Intelligence adalah satu-satunya tools yang disampaikan secara HARIAN. Ini menunjukkan betapa dinamisnya ancaman siber yang perlu dipantau setiap hari.*

Soal 6: Laporan Insiden siber disampaikan oleh PJP kepada BI dengan frekuensi...

- A. Bulanan
- B. Semesteran
- C. Sewaktu-waktu
- D. Tahunan

✓ **Jawaban: C. Sewaktu-waktu**

■ *Penjelasan: Laporan Insiden disampaikan sewaktu-waktu (kapan pun insiden terjadi), tidak menunggu jadwal pelaporan reguler.*

Soal 7: TIKI dalam konteks asesmen keandalan infrastruktur TI adalah singkatan dari...

- A. Teknologi Informasi dan Keamanan Infrastruktur
- B. Transaksi, Interkoneksi, Kompetensi, Manajemen Risiko, Infrastruktur Teknologi
- C. Tata Kelola, Identifikasi, Keamanan, Infrastruktur
- D. Teknologi, Inovasi, Keandalan, Integrasi

✓ **Jawaban: B. Transaksi, Interkoneksi, Kompetensi, Manajemen Risiko, Infrastruktur Teknologi**

■ *Penjelasan: TIKI = T(ransaksi), I(nterkoneksi), K(ompetensi), M(anajemen Risiko), I(nfrastruktur Teknologi) — lima kriteria penilaian keandalan infrastruktur TI SP.*

Soal 8: Referensi internasional yang digunakan untuk penilaian IT Governance dalam asesmen infrastruktur TI SP adalah...

- A. ISO 25010:2023 (SQuaRE)
- B. NIST 2.0 (2024) dan BIS Operational Risk (2020)
- C. PCI-DSS 4.0
- D. COBIT 2019

✓ **Jawaban: B. NIST 2.0 (2024) dan BIS Operational Risk (2020)**

■ *Penjelasan: Dimensi 2 (IT Governance / TKMR TI) menggunakan referensi NIST 2.0 (2024) dan BIS Revisions to the principles for the sound management of operational risk (2020).*

Soal 9: Skala keandalan infrastruktur TI SP dari terendah ke tertinggi adalah...

- A. Unreliable → Usually Reliable → Fairly Reliable → Reliable → Completely Reliable
- B. Not Reliable → Low Reliable → Medium Reliable → High Reliable → Fully Reliable
- C. Level 1 → Level 2 → Level 3 → Level 4 → Level 5
- D. Poor → Fair → Good → Very Good → Excellent

✓ **Jawaban: A. Unreliable → Usually Reliable → Fairly Reliable → Reliable → Completely Reliable**

■ *Penjelasan: 5 tingkat keandalan (dari rendah ke tinggi): Unreliable (Tidak Andal), Usually Reliable (Kurang Andal), Fairly Reliable (Cukup Andal), Reliable (Andal), Completely Reliable (Sangat Andal).*

Soal 10: 3 Pilar framework KKS berdasarkan PBI No. 2 Tahun 2024 adalah...

- A. Identifikasi, Proteksi, Deteksi
- B. Tata Kelola, Pencegahan, Penanganan
- C. Strategi, Operasional, Pemulihan
- D. People, Process, Technology

✓ **Jawaban: B. Tata Kelola, Pencegahan, Penanganan**

■ *Penjelasan: 3 pilar KKS: (1) Tata Kelola, (2) Pencegahan (Identifikasi-Proteksi-Deteksi), (3) Penanganan (Respons-Pemulihan). Didukung landasan Pengawasan dan Kolaborasi.*

— SOAL 11-20: FRAMEWORK KKS & EVOLUSI KEJAHATAN SIBER —**Soal 11: Komponen PENCEGAHAN dalam framework KKS mencakup tiga sub-fungsi, yaitu...**

- A. Strategi, Kebijakan, Audit
- B. Identification, Protection, Detection
- C. Response, Recovery, Rebuild
- D. Monitoring, Analisis, Pelaporan

✓ **Jawaban: B. Identification, Protection, Detection**

■ *Penjelasan: Pilar Pencegahan terdiri dari: Identification (Identifikasi), Protection (Proteksi), Detection (Deteksi). Sedangkan Response dan Recovery masuk pilar Penanganan.*

Soal 12: Analisis Dampak Bisnis (Business Impact Analysis) masuk dalam komponen KKS...

- A. Proteksi (Protection)
- B. Deteksi (Detection)
- C. Identifikasi (Identification)
- D. Tata Kelola

✓ **Jawaban: C. Identifikasi (Identification)**

■ *Penjelasan: Komponen Identifikasi mencakup: (1) Identifikasi Risiko Siber, (2) Asesmen Risiko Siber, (3) Analisis Dampak Bisnis.*

Soal 13: Prinsip KKS yang mengharuskan adanya komitmen dari pimpinan puncak adalah...

- A. Cybersecurity Culture
- B. Accountability
- C. Readiness for Incident
- D. Comprehensive Strategy

✓ **Jawaban: B. Accountability**

■ *Penjelasan: Accountability = akuntabilitas — memastikan komitmen dari pimpinan puncak (top management) dalam pengelolaan KKS.*

Soal 14: Fase evolusi kejahatan siber 2019-2021 ditandai dengan...

- A. Serangan ransomware masif ke institusi keuangan
- B. Gelombang digitalisasi SP dan kelemahan SDLC yang dieksploitasi
- C. Munculnya Ransomware-as-a-Service di darkweb
- D. Third party risk dan eksploitasi mitra API

✓ **Jawaban: B. Gelombang digitalisasi SP dan kelemahan SDLC yang dieksploitasi**

■ *Penjelasan: 2019-2021 bertema "Find and Exploit" — dimanfaatkan saat banyak pelaku SP mengembangkan mobile apps dengan SDLC yang belum matang, membuka celah yang dieksploitasi fraudster.*

Soal 15: Ransomware-as-a-Service (RaaS) menjadi fenomena signifikan pada periode...

- A. 2019-2021
- B. 2021-2023
- C. 2024-2025
- D. 2025-2026

✓ **Jawaban: B. 2021-2023**

■ *Penjelasan: 2021-2023 bertema "Extort and Gain Fame" — serangan siber makin affordable karena munculnya RaaS di darkweb, pelaku mencari publisitas dengan menyerang institusi besar.*

Soal 16: Fenomena "resurfaced breach" dalam evolusi kejahatan siber adalah...

- A. Serangan siber baru yang mengeksploitasi kelemahan lama
- B. Data yang sebelumnya bocor dipublikasikan ulang di forum black hat untuk mencari popularitas
- C. Pemulihan data setelah serangan ransomware
- D. Kebocoran data yang baru terjadi di tahun 2024-2025

✓ **Jawaban: B. Data yang sebelumnya bocor dipublikasikan ulang di forum black hat untuk mencari popularitas**

■ *Penjelasan: "Resurfaced breach" = data lama yang sudah pernah bocor, kemudian dipublikasikan ulang oleh pihak lain semata-mata untuk mencari popularitas dan reputasi di komunitas black hat hacker.*

Soal 17: Tren kejahatan siber paling dominan di periode 2025-2026 adalah...

- A. Bug pada mobile banking app
- B. Ransomware pada data center bank
- C. Third Party Risk — eksploitasi mitra/vendor PSP
- D. Phishing kepada nasabah

✓ **Jawaban: C. Third Party Risk — eksploitasi mitra/vendor PSP**

■ *Penjelasan: 2025-2026 bertema "Third Party Risk" — setelah PSP memperkuat KKS internal, pelaku ancaman mencari celah di mitra PSP (managed service, vendor development, partner API).*

Soal 18: Pelaku ancaman siber terbanyak (22%) menurut data ISACA adalah...

- A. Nation State Attackers
- B. Hackers
- C. Cybercriminals
- D. Hacktivist

✓ **Jawaban: C. Cybercriminals**

■ *Penjelasan: Most Common Threat Actors: #1 Cybercriminals (22%), #2 Hackers (19%), #3 Malicious Insiders (11%), #4 Non-malicious Insiders (10%), #5 Nation State Attackers (9%), #6 Hacktivist (8%).*

Soal 19: Top 3 Attack Vector berdasarkan BSSN 2024 adalah...

- A. Phishing, Malware, DDoS
- B. Active Scanning (T1595), Compromised Account (T1586), Exploit Public-Facing Application (T1190)
- C. SQL Injection, XSS, CSRF
- D. Ransomware, Trojan, Worm

✓ **Jawaban: B. Active Scanning (T1595), Compromised Account (T1586), Exploit Public-Facing Application (T1190)**

■ *Penjelasan: Top 3 Attack Vector BSSN 2024 menggunakan kode MITRE ATT&CK: T1595 (Active Scanning), T1586 (Compromised Account), T1190 (Exploit Public-Facing Application).*

Soal 20: Ransomware yang paling dikenal secara global dan termasuk Top 5 di Indonesia adalah...

- A. LockBit saja
- B. WannaCry saja
- C. Lunamoth, WannaCry, Locky, LockBit, GandCrab
- D. Petya, NotPetya, REvil

✓ **Jawaban: C. Lunamoth, WannaCry, Locky, LockBit, GandCrab**

■ *Penjelasan: Top 5 Ransomware di Indonesia menurut BSSN 2024: Lunamoth, WannaCry, Locky, LockBit, dan GandCrab.*

— SOAL 21-30: PENANGANAN KASUS SIBER & TOOLS KEAMANAN —

Soal 21: SDLC yang lemah mengakibatkan jenis ancaman...

- A. Ransomware pada server
- B. Kesalahan logis aplikasi (logic error) yang dapat dieksploitasi
- C. DDoS pada infrastruktur jaringan
- D. Kebocoran data melalui mitra API

✓ **Jawaban: B. Kesalahan logis aplikasi (logic error) yang dapat dieksploitasi**

■ *Penjelasan: SDLC (Software Development Lifecycle) yang lemah menghasilkan bug/celah logis pada aplikasi. Contoh: bug mobile banking yang mentransfer dana tanpa mendebit saldo, atau bug manipulasi nilai tips pada QRIS.*

Soal 22: Contoh kasus SDLC lemah yang disebutkan dalam materi adalah...

- A. Eksploitasi middleware untuk transfer dana ilegal
- B. Bug mobile banking — saldo bertambah tanpa transaksi dan skimming ATM
- C. Kebocoran data melalui vendor managed service
- D. Serangan ransomware pada core banking

✓ **Jawaban: B. Bug mobile banking — saldo bertambah tanpa transaksi dan skimming ATM**

■ *Penjelasan: Kasus SDLC lemah (2019-2021): bug transfer dana tanpa debit saldo, bug saldo bertambah/berkurang tanpa transaksi finansial, dan skimming (bug ATM yang belum memenuhi SNTC).*

Soal 23: Dalam kasus fraud APMK via EDC/Mini ATM, Bank Acquirer DILARANG menggunakan...

- A. EDC berbasis chip EMV
- B. EDC berbasis Android
- C. EDC dengan fitur purchase
- D. EDC yang terkoneksi langsung ke bank

✓ **Jawaban: B. EDC berbasis Android**

■ *Penjelasan: Langkah pencegahan sebagai Bank Acquirer: MELARANG penggunaan EDC berbasis Android, dan memastikan perangkat bukan Mini-ATM. Fitur EDC di merchant hanya untuk purchase (tanpa transfer dana).*

Soal 24: ARPC dalam konteks validasi transaksi EDC adalah...

- A. Automated Risk Prevention Control
- B. Authentication Response Crypto — nilai kriptografis yang memvalidasi kewajaran transaksi EMV
- C. Advanced Request Processing Code
- D. Account Recovery Protection Certificate

✓ **Jawaban: B. Authentication Response Crypto — nilai kriptografis yang memvalidasi kewajaran transaksi EMV**

■ *Penjelasan: ARPC = Authentication Response Crypto = nilai kriptografis dalam standar EMV yang digunakan untuk memvalidasi kewajaran data transaksi kartu. Bank Issuer wajib memvalidasi kewajaran nilai ARPC.*

Soal 25: Dalam kasus Risiko Anomali Transaksi Wholesale Payment, hard token berfungsi untuk...

- A. Enkripsi data nasabah
- B. Otentikasi setiap transaksi wholesale payment
- C. Akses masuk ke ruang server
- D. Tanda tangan digital dokumen

✓ **Jawaban: B. Otentikasi setiap transaksi wholesale payment**

■ *Penjelasan: Hard Token = perangkat fisik yang menghasilkan kode OTP untuk otentikasi (autentikasi) setiap transaksi Wholesale Payment. Bila disalahgunakan, dapat mengirim pesan "success transaction" palsu.*

Soal 26: PAM dalam konteks keamanan akses server adalah...

- A. Personal Access Management
- B. Privileged Access Management
- C. Password Authentication Module
- D. Protected Access Mechanism

✓ **Jawaban: B. Privileged Access Management**

■ *Penjelasan: PAM = Privileged Access Management = sistem untuk mengelola, memantau, dan mengontrol akses istimewa (privileged access) ke sistem kritis. Akses RDP, VNC, SSH harus dialihkan melalui PAM.*

Soal 27: EDR/XDR dalam konteks keamanan endpoint adalah...

- A. Endpoint Data Recovery / Extended Data Recovery
- B. Endpoint Detection and Response / Extended Detection and Response
- C. Enterprise Data Repository / Extended Data Repository
- D. Emergency Defense Response / Extended Defense Response

✓ **Jawaban: B. Endpoint Detection and Response / Extended Detection and Response**

■ *Penjelasan: EDR = Endpoint Detection and Response (pada endpoint/perangkat), XDR = Extended Detection and Response (mencakup lebih luas: network, cloud, dsb). Keduanya tools keamanan untuk deteksi dan respons ancaman.*

Soal 28: SIEM dalam konteks monitoring keamanan adalah...

- A. Security Incident and Event Management
- B. System Integration and Event Monitoring
- C. Security Information and Event Management
- D. Secure Infrastructure and Endpoint Management

✓ **Jawaban: C. Security Information and Event Management**

■ *Penjelasan: SIEM = Security Information and Event Management = platform yang mengumpulkan dan menganalisis log dari berbagai security tools (AV, EDR, PAM, firewall) secara terpusat untuk memantau kewajarannya.*

Soal 29: MFA dalam konteks akses VPN dan PAM adalah...

- A. Multi-Factor Authentication — verifikasi identitas dengan lebih dari satu faktor
- B. Multi-Function Access — akses dengan berbagai privilege
- C. Managed Firewall Application — aplikasi firewall terkelola
- D. Master Function Authentication — autentikasi utama sistem

✓ **Jawaban: A. Multi-Factor Authentication — verifikasi identitas dengan lebih dari satu faktor**

■ *Penjelasan: MFA = Multi-Factor Authentication = metode autentikasi yang memerlukan lebih dari satu bukti identitas (password + OTP + biometrik, dll). Wajib diterapkan untuk akses VPN dan PAM.*

Soal 30: WAF dalam pencegahan risiko Cyber Fraud melalui mitra API adalah...

- A. Wide Area Firewall
- B. Web Application Firewall
- C. Wireless Access Framework
- D. Web Authentication Factor

✓ **Jawaban: B. Web Application Firewall**

■ *Penjelasan: WAF = Web Application Firewall = firewall khusus untuk melindungi aplikasi web dari serangan seperti SQL Injection, XSS, dan serangan berbasis web lainnya. Wajib diimplementasi di server terkait layanan API pembayaran.*

— SOAL 31-40: FDS, FORENSIK, HASIL ASESMEN & UMUM —**Soal 31: FDS dalam konteks pemantauan transaksi siber adalah...**

- A. Financial Data System
- B. Fraud Detection System
- C. Full Defense Strategy
- D. Forensic Data Service

✓ **Jawaban: B. Fraud Detection System**

■ *Penjelasan: FDS = Fraud Detection System = sistem untuk mendeteksi aktivitas anomali/fraud pada level transaksi, akun, maupun jaringan secara 24/7. Wajib dimiliki setiap PSP.*

Soal 32: Langkah penanganan insiden siber yang selalu PERTAMA dilakukan adalah...

- A. Melakukan audit forensik
- B. Melakukan analisa atas log transaksi yang dianggap anomali
- C. Me-rebuild infrastruktur yang terdampak
- D. Melaporkan ke BSSN

✓ **Jawaban: B. Melakukan analisa atas log transaksi yang dianggap anomali**

■ *Penjelasan: Langkah penanganan universal yang selalu pertama: (1) Analisa log transaksi anomali → (2) Money trail + koordinasi IASC → (3) Identifikasi infrastruktur terdampak → dst.*

Soal 33: IASC dalam koordinasi penanganan insiden siber adalah...

- A. Indonesian Anti-Scam Centre
- B. International Automated Security Center
- C. Internal Audit Security Committee
- D. Internet Access Security Control

✓ **Jawaban: A. Indonesian Anti-Scam Centre**

■ *Penjelasan: IASC = Indonesian Anti-Scam Centre = pusat koordinasi penanganan kejahatan siber dan penipuan berbasis digital di Indonesia. PSP wajib berkoordinasi dengan IASC saat terjadi insiden.*

Soal 34: Perbedaan utama antara kasus Fraud APMK vs kasus Middleware Cyber Heist terkait audit forensik adalah...

- A. Kasus APMK tidak perlu audit forensik, Middleware perlu
- B. Kedua kasus memerlukan audit forensik
- C. Kasus SDLC lemah tidak memerlukan audit forensik
- D. Tidak ada perbedaan

✓ **Jawaban: B. Kedua kasus memerlukan audit forensik**

■ *Penjelasan: Kasus APMK Fraud, Wholesale Payment, dan Cyber Heist Middleware SEMUANYA memerlukan audit forensik. Yang TIDAK memerlukan audit forensik adalah kasus Kesalahan Logis Aplikasi (SDLC Lemah) karena bukan serangan eksternal melainkan bug internal.*

Soal 35: Prinsip "least privilege access" dalam keamanan server berarti...

- A. Setiap pengguna memiliki akses penuh ke semua sistem
- B. Setiap pengguna hanya mendapat hak akses minimal yang diperlukan untuk tugasnya
- C. Akses hanya diberikan kepada pimpinan tertinggi
- D. Semua akses menggunakan satu akun bersama

✓ **Jawaban: B. Setiap pengguna hanya mendapat hak akses minimal yang diperlukan untuk tugasnya**

■ *Penjelasan: Least Privilege Access = prinsip keamanan di mana setiap pengguna/sistem hanya diberikan hak akses minimal yang diperlukan untuk menjalankan tugasnya — mengurangi risiko akses tidak sah.*

Soal 36: SNAP dalam konteks keamanan API pembayaran adalah...

- A. Standar Nasional Open API Pembayaran
- B. Security Network Access Protocol
- C. Standard Network Application Process
- D. Secure Network API Payment

✓ **Jawaban: A. Standar Nasional Open API Pembayaran**

■ *Penjelasan: SNAP = Standar Nasional Open API Pembayaran = standar teknis nasional untuk keterhubungan antara bank dan fintech. Standar Teknis dan Keamanan SNAP wajib dipatuhi oleh PJP penyedia maupun mitra API.*

Soal 37: Hasil asesmen 35 Bank Besar menunjukkan rerata skor infrastruktur TI (Faktor I) sebesar...

- A. 2,50 (Kurang Andal)
- B. 3,00 (Cukup Andal)
- C. 3,85 (mendekati Andal)
- D. 4,50 (Andal)

✓ **Jawaban: C. 3,85 (mendekati Andal)**

■ *Penjelasan: Rerata skor 35 Bank Besar = 3,85, berada di antara "Cukup Andal" (3) dan "Andal" (4). Distribusi: 1 Kurang Andal, 18 Cukup Andal, 16 Andal, 0 Sangat Andal.*

Soal 38: Suptech yang sedang dikembangkan BI untuk meningkatkan efektivitas surveilans mencakup...

- A. Pengembangan mobile app untuk nasabah
- B. Data collection dan data analytics
- C. Sistem trading otomatis
- D. Platform blockchain untuk transaksi

✓ **Jawaban: B. Data collection dan data analytics**

■ *Penjelasan: Suptech = Supervisory Technology. BI sedang mengembangkan Suptech dari dua sisi: data collection (pengumpulan data lebih efisien) dan data analytics (analisis data lebih canggih untuk mendukung surveilans).*

Soal 39: CI/CD dalam konteks pencegahan risiko SDLC adalah...

- A. Cybersecurity Intelligence / Cyber Defense
- B. Continuous Integration / Continuous Deployment
- C. Critical Infrastructure / Critical Data
- D. Centralized Infrastructure / Centralized Deployment

✓ **Jawaban: B. Continuous Integration / Continuous Deployment**

■ *Penjelasan: CI/CD = Continuous Integration/Continuous Deployment = praktik pengembangan software yang mengotomasi pengujian dan deployment, memastikan setiap perubahan kode telah melalui pengujian yang memadai sebelum masuk production.*

Soal 40: Kutipan penutup dari materi ini adalah "Banks today are more likely to be brought down by..." yang melengkapi kutipan tersebut adalah...

- A. "...a data breach than by market risks"
- B. "...cyber attacks than by natural disasters"
- C. "...a missed security alert than by bad loans"
- D. "...ransomware than by bank runs"

✓ **Jawaban: C. "...a missed security alert than by bad loans"**

■ *Penjelasan: Kutipan penutup lengkap: "Banks today are more likely to be brought down by a missed security alert than by bad loans." — Menggambarkan betapa kritisnya keamanan siber bagi industri perbankan saat ini.*

BONUS — KAMUS ISTILAH & CHEAT SHEET

Kamus Istilah Penting Risiko Siber SP

Istilah	Penjelasan
KKS	Keamanan Sistem Informasi dan Ketahanan Siber — kerangka keamanan siber BI
PSP	Payment Service Provider — Penyedia Jasa Pembayaran
PJP	Penyedia Jasa Pembayaran (sama dengan PSP dalam konteks regulasi BI)
DSPPK	Departemen Surveilans Sistem Pembayaran dan Pelindungan Konsumen
Surveilans	Pemantauan, identifikasi, dan penilaian risiko penyelenggara SP oleh BI
Suptech	Supervisory Technology — teknologi untuk meningkatkan efektivitas pengawasan
TIKI	Transaksi, Interkoneksi, Kompetensi, Manajemen Risiko, Infrastruktur Teknologi
Ransomware	Malware yang membatasi akses komputer sampai tebusan dibayar
RaaS	Ransomware-as-a-Service — layanan ransomware yang dijual di darkweb
Cyber Heist	Pencurian dana secara digital — tren dominan 2024-2025
SDLC	Software Development Lifecycle — siklus pengembangan perangkat lunak
APMK	Alat Pembayaran Menggunakan Kartu (ATM/Debit/Kredit)
EDC	Electronic Data Capture — mesin gesek kartu di merchant
HSM	Hardware Security Module — perangkat keras pengaman kriptografi
Middleware	Lapisan perangkat lunak penghubung antar sistem (contoh: antara aplikasi dan core banking)
Core Banking	Sistem utama operasional perbankan (rekening, transaksi, dll)
IASC	Indonesian Anti-Scam Centre — pusat koordinasi penanganan kejahatan siber
ARPC	Authentication Response Crypto — nilai kriptografis validasi transaksi EMV
EMV	Standar internasional kartu chip (Europay, Mastercard, Visa)
SNTC	Standar Nasional Teknologi Chip — standar keamanan chip kartu ATM/Debet Indonesia
Hard Token	Perangkat fisik penghasil OTP untuk otentikasi transaksi wholesale payment
PAM	Privileged Access Management — sistem kelola akses istimewa ke sistem kritis
FDS	Fraud Detection System — sistem deteksi fraud 24/7
EDR	Endpoint Detection and Response — tools deteksi ancaman di endpoint
XDR	Extended Detection and Response — deteksi ancaman lebih luas (endpoint+network+cloud)
SIEM	Security Information and Event Management — platform monitoring log terpusat
MFA	Multi-Factor Authentication — autentikasi lebih dari satu faktor
WAF	Web Application Firewall — firewall khusus aplikasi web
SNAP	Standar Nasional Open API Pembayaran
API	Application Programming Interface — antarmuka pemrograman aplikasi
CI/CD	Continuous Integration/Continuous Deployment — praktik DevOps

Istilah	Penjelasan
Pentest	Penetration Testing — uji penetrasi keamanan sistem
Forensik Digital	Investigasi digital untuk menemukan bukti insiden siber
Darkweb	Bagian tersembunyi internet yang tidak terindeks mesin pencari — tempat jual beli ilegal
Account Takeover	Pengambilalihan akun korban oleh pelaku kejahatan siber
Resurfaced Breach	Data lama yang bocor dipublikasikan ulang untuk mencari popularitas
Third Party Risk	Risiko yang datang dari pihak ketiga/mitra/vendor yang bekerja sama
C&C; Server	Command and Control Server — server yang digunakan penyerang untuk mengendalikan malware

CHEAT SHEET — RINGKASAN SUPER SINGKAT

Regulasi Utama Siber	PBI No. 2 Tahun 2024 tentang KKS (Keamanan Sistem Informasi & Ketahanan Siber)
3 Pilar KKS	Tata Kelola + Pencegahan (Identifikasi-Proteksi-Deteksi) + Penanganan (Respons-Pemulihan)
Siklus Pengawasan SP	Surveilans → Pemeriksaan (Full Scope/Thematic) → Evaluasi & Tindak Lanjut
4 Pilar Pengawasan	People Policy Process Technology
Kriteria TIKI	Transaksi, Interkoneksi, Kompetensi, Manajemen Risiko, Infrastruktur Teknologi
3 Dimensi Penilaian Infrastruktur	Infrastruktur Standar Minimum + Governance SP + Keamanan Siber SP
Skala Keandalan	Unreliable → Usually → Fairly Reliable → Reliable → Completely Reliable
Hasil 35 Bank Besar	Skor 3,85 → 1 Kurang Andal, 18 Cukup Andal, 16 Andal, 0 Sangat Andal
Evolusi 2019-2021	"Find & Exploit" — SDLC lemah, bug mobile banking, skimming
Evolusi 2021-2023	"Extort & Gain Fame" — RaaS di darkweb, ransomware bank, DDoS, kebocoran data
Evolusi 2024-2025	Cyber Heist — pencurian dana, eksploitasi middleware, account takeover
Evolusi 2025-2026	Third Party Risk — celah di mitra/vendor/API, data eksfiltrasi
Top Threat Actors	Cybercriminals (22%), Hackers (19%), Malicious Insiders (11%)
Top 3 Attack Vector	Active Scanning (T1595), Compromised Account (T1586), Exploit App (T1190)
Top 5 Ransomware Indonesia	Lunamoth, WannaCry, Locky, LockBit, GandCrab
Langkah Penanganan Umum	Log Analysis → Money Trail+IASC → Identifikasi Infra → Pengamanan → Forensik → Investigasi → Rebuild
Pencegahan SDLC Lemah	CI/CD + QA untuk semua skenario + FDS 24/7 + Respons cepat post-deployment
Pencegahan Middleware Attack	Firewall + MFA VPN/PAM + Antivirus/EDR-XDR + SIEM + Tutup RDP/SSH/FTP
Pencegahan Mitra API Risk	Kepatuhan SNAP + WAF + FDS + Audit berkala kesesuaian SNAP
Prinsip KKS	Accountability Comprehensive Strategy Embedded Cyber Risk Mgmt Cybersecurity Culture Readiness for Incident

Catatan belajar ini disusun berdasarkan materi PPT "Pengenalan dan Pengawasan Risiko Siber pada Industri Sistem Pembayaran" — Departemen Surveilans Sistem Pembayaran dan Pelindungan Konsumen, Bank Indonesia, 23 April 2026. Dipersiapkan untuk persiapan ujian PCPM.